101 BİTİRME PROJESİ

"Analist ve Avcı"

03 KASIM 2026

BETÜL ZEHRA AKSU

İçindekiler

FAZ 1: "Siber Triatlon" 2
BÖLÜM A 2
BÖLÜM B 2
BÖLÜM D 4

FAZ 1: "Siber Triatlon"

BÖLÜM A

1. *İşletim Sistemi ve Şifreleme*

*SSH Özel Anahtar (Gizli Anahtar):*SSH anahtar'ı dairenizin kapısının anahtarı , Parolayı apartman dış kapısının anahtarı gibi düşünebiliriz .Evinize yabancıların girmesini istemezsiniz işte bu yüzden daire anahtarınız kişiseldir ama apartmanın dış kapısının anahtarı diğer dairelerde de vardır. Dış kapı anahtarı ile daire anahtarı aynı olursa evinize herkes girebilir.

*Hex Dump:*Dosyaya farklı bakış açısıyla bakmayı sağlar senin gördüğün metindir Hex Dump sayesinde o metnin arkasında saklanan bilgileri gösterir.

2. *Web Mimarisi*

Client-Side vs Server-Side: Sağ tık >Kaynak İncele dediğimizde gördüğümüz HTML ve JavaScript kodları olur. Python ve PHP kodları ise arkaplanda çalışır, Python ve PHP kodlarını görmemizin sebebi bilgisayarın çıktı olarak sadece HTML ve JavaScript kodlarını gösterir, Python kodunu okuyamaz gibi düşünebiliriz.

Komut Enjeksiyonu: Resim aratıyorsun arkada Linux du -h resim.jpg komutuyla çalışır resim boyutuna bakar. Whoami kodu hangi yetkiye sahip olduğunu söyler, ls komutu ise listelemek için kullanılabilir başka hangi dosyalar var diye bakar.

3. *Ağ Anatomisi*

C2 (Komuta ve Kontrol) Nedir: Bilgisayara zararlı yazılım yüklendiğinde C2'ye dayanmasının sebebi uzaktan cihazı kontrol etmek, çaldığı belgeleri hızlıca iletmek ve herhangi antivirüse karşı güncel kalmaktır.

*PCAP Analizi:*SOC analistleri için antivirüs yetmez çünkü sadece kırmızı listede adı olanlar vardır antivirüste,PCAP'te ise ağdaki tüm paketlerin zararlı faydalı listesi vardır herhangi bir dosyasız saldırıda PCAP'e ihtiyaç duyar ,önceki kayıtlara bakabilir.Ağdaki paketlerin hepsine bakma şansı yaratır.

BÖLÜM B

Cephe 1: İşletim Sistemleri Ustası (Linux / Bash)

Level 13'te SSh Private key kullanırken sistemde sshkey.private isimli RSA Özel Anahtarını (Private Key) kullanarak Anahtar Tabanlı Kimlik Doğrulama yaptık. SSH bağlantısı kurarken -i komutunu kullanarak bu anahtar dosyasını sisteme kimlik kanıtı olarak sunduk. Böylece direkt bandit14 kullanıcısına geçtik.

ssh -i sshkey.private bandit14@bandit.labs.overthewire.org -p 2220

```
PS C:\Users\Asus\Desktop> ssh -i sshkey.private bandit14@bandit.labs.
overthewire.org -p 2220

                      This is an OverTheWire game server.
            More information on http://www.overthewire.org/wargames

backend: gibson-0

Welcome to OverTheWire!

If you find any problems, please report them to the #wargames channel
 on
discord or IRC.

--[ Playing the games ]--

  This machine might hold several wargames.
```

Bandit14 kullanıcısından cat komutuyla şifresini okuduk,parolayı localhost dinleme yapan 30000 numaralı TCP portuna iletmek için nc aracı kullandık echo komutuyla oluşturduktan sonra Linux Pipe (|) operatörü kullanılarak nc localhost 30000 bağlantısına gönderdik. Parola doğrulanarak level 15'i açtık.

cat /etc/bandit_pass/bandit14

echo "MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS" | nc localhost 30000

```
--[ Tools ]--

 For your convenience we have installed a few useful tools which you
can find
 in the following locations:

    * gef (https://github.com/hugsy/gef) in /opt/gef/
    * pwndbg (https://github.com/pwndbg/pwndbg) in /opt/pwndbg/
    * gdbinit (https://github.com/gdbinit/Gdbinit) in /opt/gdbinit/
    * pwntools (https://github.com/Gallopsled/pwntools)
    * radare2 (http://www.radare.org/)

--[ More information ]--

  For more information regarding individual wargames, visit
  http://www.overthewire.org/wargames/

  For support, questions or comments, contact us on discord or IRC.

  Enjoy your stay!

bandit14@bandit:~$ cat /etc/bandit_pass/bandit14
MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS
bandit14@bandit:~$ echo "KOPYALADIGIN_YENI_SIFRE" | nc localhost 3000
0
Wrong! Please enter the correct current password.
bandit14@bandit:~$ echo "MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS" | nc local
host 30000
Correct!
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo

bandit14@bandit:~$
```

PASSWORD

LEVEL 11: dtR173fZKb0RRsDFSGsg2RWnpNVj3qRr

LEVEL 12: 7x16WNeHIi5YkIhWsfFIqoognUTyj9Q4

LEVEL 13: FO5dwFsc0cbaIiH0h8J2eUks2vdTDwAn

LEVEL 14: MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS

LEVEL 15: 8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo

BÖLÜM D

1. **Etki Analizi (Impact & CVSS Mantığı)**

Hakkımızda sayfasında bulduğumuz zafiyet düşük/orta seviyeli bir risk CVSS skoru 4.5 ; iç ağdaki zafiyet yüksek risk seviyesinde skoru 9.0 , saldırgan her şeye yönetici panelinde daha kolay erişim sağlayabilir yaratacağı hasar daha fazla olur iç ağda.

2. **Çözüm Üretmek (Azaltma)**

Tek tırnak yasaklamak çok bir şeyi değiştirmez saldırganı tam engellemez ya da herhangi bir karakteri yasaklamak kesin çözüm değil saldırganı belli bir süre oyalabilir ama engellemez. Saldırgan tek tırnak kullanmak yerine başka bir karakter kullanarak filtrelemeyi kaldırabilir.Parametrik Sorgular, veri ile komutu birbirinden tamamen ayırmak daha kalıcı bir çözümdür.